

Enterprise Security Strategy



Incident Management & Response

- Incident Response Plan
- Incident Response Team
- Incident Communication Channels
- NIST Incident Response Lifecycle
- Case Study: The LinkedIn Breach

Labs:

- Students build a playbook using Flexible IR

Incident Management

- Incident Management in cybersecurity is the structured process of *detecting, analyzing, containing, eradicating, and recovering* from security incidents, while minimizing business impact and meeting legal and regulatory obligations.
- It is a core capability of SOC, IT operations, and GRC functions.
- Objectives of Incident Management:
 - Rapid detection and response
 - Minimize business disruption
 - Prevent lateral spread
 - Preserve forensic evidence
 - Meet compliance requirements
 - Improve future security posture



Lifecycle of Incident Management

▪ Phase 1: Preparation

- Incident Response (IR) policy
- Defined roles and escalation matrix
- Playbooks and runbooks
- Logging and monitoring
- Training and tabletop exercises

▪ Phase 2: Identification

- Alerts from SIEM, EDR, XDR
- User-reported incidents
- Log and IOC analysis
- Incident severity classification

▪ Phase 3: Containment

- Short-term containment (isolate systems)
- Long-term containment (patch, segmentation)
- Credential resets
- Blocking malicious indicators

▪ Phase 4: Eradication

- Remove malware
- Close exploited vulnerabilities
- Remove persistence mechanisms
- Harden affected systems

▪ Phase 5: Recovery

- Restore systems from clean backups
- Validate system integrity
- Monitor for reinfection
- Resume business operations

▪ Phase 6: Lessons Learned

- Root cause analysis
- Incident report
- Control improvements
- Update playbooks

Roles and Responsibilities

- **Incident Manager** – Overall coordination
- **SOC Analysts** – Detection and analysis
- **IT Ops** – System recovery
- **Legal/Compliance** – Regulatory reporting
- **PR/Communications** – External messaging
- **Management** – Decision-making



Common Incident Types

Incident	Example Response
Phishing	Account reset, email purge
Malware	Isolate endpoint, scan
Ransomware	Disconnect network, restore
Data breach	Containment, legal review
DDoS	Traffic filtering, ISP coordination

Incident Response Plan (IRP)

- An Incident Response Plan (IRP) is a formal, documented framework that defines how an organization **prepares for, detects, responds to, and recovers** from cybersecurity incidents.
- It is a mandatory control under major standards such as ISO 27001, NIST, and CERT-In directives.
- Main objectives of an Incident Response Plan includes:
 - ✓ Minimize impact to business operations
 - ✓ Rapidly contain and eradicate threats
 - ✓ Preserve forensic evidence
 - ✓ Ensure legal and regulatory compliance
 - ✓ Restore services securely
 - ✓ Improve security posture through lessons learned



Tools Supporting Incident Response

- **SIEM** (Security Information and Event Management)
- **EDR** (Endpoint Detection & Response) / **XDR** (Extended Detection & Response)
- **SOAR** (Security Orchestration, Automation, and Response).
- **Network monitoring tools** – Wireshark, NetFlow, Snort
- **Forensic analysis tools** – Forensic ToolKit (FTK), EnCase, Autopsy
- **Ticketing and case management systems** – ServiceNow, Jira, BMC Remedy



Incident Response Team (IRT)

- An Incident Response Team (IRT) is a **cross-functional group of trained personnel** responsible for **preparing for, detecting, analyzing, containing, eradicating, and recovering** from cybersecurity incidents.
- The IRT operates under a defined Incident Response Plan (IRP) and aligns with standards such as NIST SP 800-61 and ISO/IEC 27035.
- Main objectives of an Incident Response Team:
 - ✓ Rapid incident detection and validation
 - ✓ Minimize business impact and downtime
 - ✓ Contain and eradicate threats effectively
 - ✓ Preserve forensic evidence
 - ✓ Ensure regulatory and legal compliance
 - ✓ Capture lessons learned for continuous improvement



Core Roles and Responsibilities

- **Incident Response Manager / Incident Commander**
 - Overall authority during an incident
 - Decision-making and escalation
 - Coordinates technical, legal, and business stakeholders
 - Approves containment and recovery actions
- **SOC Analysts (Tier 1 / Tier 2 / Tier 3)**
 - Tier 1: Alert triage and initial investigation
 - Tier 2: Deep analysis and incident confirmation
 - Tier 3: Threat hunting, advanced malware analysis, root cause
- **Digital Forensics & Malware Analysts**
 - Disk, memory, and network forensics
 - Malware reverse engineering
 - Evidence preservation and chain of custody



Core Roles and Responsibilities

- **Network & System Administrators**

- Isolation of affected systems
- Patching, configuration changes, and recovery
- Log collection from infrastructure

- **Threat Intelligence Analyst**

- Identifies IOCs, TTPs, and threat actor attribution
- Maps activity to MITRE ATT&CK
- Enriches incidents with external intelligence

- **Legal & Compliance Team**

- Regulatory reporting (CERT-In, GDPR, DPDP Act, etc.)
- Law enforcement coordination
- Ensures actions meet legal obligations

Core Roles and Responsibilities

- **Communications / PR Team**

- Internal and external communications
- Customer and stakeholder notifications
- Reputation management

- **Business Owner / Application Owner**

- Business impact assessment
- Recovery prioritization
- Acceptance of residual risk

Incident Response Team Structure Models

- **Centralized IRT**

- Single enterprise team
- High expertise, consistent processes
- Suitable for mid to large organizations

- **Distributed IRT**

- Regional or business-unit based teams
- Faster local response
- Requires strong coordination

- **Hybrid IRT**

- Central command with regional execution
- Most commonly adopted model

Tools Commonly Used by IRT

- **SIEM:** Splunk, QRadar, Sentinel
- **EDR/XDR:** Defender, CrowdStrike
- **Forensics:** FTK, EnCase, Volatility
- **Case Management:** ServiceNow, TheHive
- **Threat Intel:** MISP, VirusTotal

Incident Communication Channels

- Incident Communication Channels define the **formal and secure paths** through which information is shared during a cybersecurity incident.
- Effective channels ensure **timely coordination, accurate messaging, confidentiality, and compliance**, while preventing misinformation and panic.
- Main objectives of Incident Communication:
 - ✓ Enable rapid coordination among response teams
 - ✓ Maintain confidentiality and data integrity
 - ✓ Ensure consistent and approved messaging
 - ✓ Meet regulatory and contractual obligations
 - ✓ Support decision-making under time pressure



Core Incident Communication Channels

- **Internal Technical Channels**

- Used by SOC, IRT, IT, and security teams.
- Examples - Secure email (Microsoft 365 with DLP)

- **Executive & Management Communication**

- Used for leadership awareness and decision-making.
- Examples - Executive brief emails

- **Legal, Compliance & Risk Communication**

- Used for regulatory and legal coordination.
- Examples - Encrypted legal email channels

- **External Stakeholder Communication**

- Used when third parties are impacted.
- Examples - Vendor / partner secure portals



Core Incident Communication Channels

- **Customer & Public Communication**

- Used only after legal and executive approval.
- Examples - Official company website notices

- **Law Enforcement & CERT Communication**

- Used for mandatory reporting and investigation support.
- Examples - CERT-In reporting portal (India)

NIST Incident Response Lifecycle

- The NIST Incident Response Lifecycle is a **structured, industry-accepted model** that defines how organizations **should prepare for, detect, respond to, and recover** from cybersecurity incidents.
- It is outlined in NIST Special Publication 800-61 – Computer Security Incident Handling Guide.
- The lifecycle consists of four continuous phases:
 - Preparation
 - Detection and Analysis
 - Containment, Eradication, and Recovery
 - Post-Incident Activity



NIST Incident Response Lifecycle - Preparation

- Ensure the organization is ready to handle incidents effectively before they occur.
- Key Activities
 - Establish an Incident Response Team (IRT)
 - Define policies, procedures, and escalation paths
 - Deploy security controls (SIEM, EDR, IDS/IPS)
 - Maintain asset inventory and data classification
 - Conduct training and tabletop exercises
 - Establish communication and legal processes
- Deliverables
 - Incident Response Plan (IRP)
 - Playbooks and SOPs
 - Contact lists and communication matrix



NIST Incident Response Lifecycle - Detection and Analysis

- Identify potential incidents, determine their scope, and assess impact.
- Key Activities
 - Monitor alerts from SIEM, EDR, NDR
 - Triage and validate security events
 - Classify incident type and severity
 - Analyze logs, endpoints, and network traffic
 - Identify Indicators of Compromise (IOCs)
 - Map attacker behavior to MITRE ATT&CK
- Deliverables
 - Incident tickets and timelines
 - Severity classification
 - Initial impact assessment



NIST Incident Response Lifecycle - Containment, Eradication, and Recovery

Stop the attack, remove the threat, and restore normal operations safely.

- **Containment**

- Isolate affected systems
- Block malicious IPs/domains
- Disable compromised accounts

- **Eradication**

- Remove malware and persistence mechanisms
- Patch vulnerabilities
- Reset credentials
- Harden configurations

- **Recovery**

- Restore systems from clean backups
- Validate system integrity
- Monitor for re-infection
- Gradual return to production

- **Deliverables**

- Clean systems
- Recovery validation reports
- Monitoring plans

NIST Incident Response Lifecycle - Post-Incident Activity (Lessons Learned)

- Improve future response by learning from the incident.
- Key Activities
 - Conduct post-incident review
 - Identify control gaps and failures
 - Update IR plans and playbooks
 - Enhance detection rules
 - Report to management and regulators
- Deliverables
 - Lessons Learned Report
 - Updated policies and controls
 - Improvement action items



Case Study: The LinkedIn Breach

- The LinkedIn breach is one of the most cited examples of **large-scale credential compromise driven by weak password, practices and secondary data abuse**.
- While the original breach occurred in **2012**, its impact resurfaced dramatically in **2016** when the stolen data was publicly disclosed, affecting **over 117 million users**.
- The incident highlights critical failures in **password protection, cryptographic controls, and long-term incident handling**.



Case Study: The LinkedIn Breach

- Background of the Incident
 - **Organization:** LinkedIn (Professional Networking Platform)
 - **Initial Breach:** 2012
 - **Public Disclosure of Full Dataset:** 2016
 - **Records Exposed:** ~117 million user accounts
- Data Type:
 - Email addresses
 - Password hashes (unsalted SHA-1)



Case Study: Primary Cause

- **Weak password hashing algorithm** (SHA-1)
- **No cryptographic salting**
- Allowed attackers to crack passwords at scale using:
 - Rainbow tables
 - GPU-based brute-force attacks
- How the Attack Occurred
 1. Attacker compromised LinkedIn systems (details undisclosed)
 2. Extracted user credential database
 3. Passwords stored using unsalted SHA-1
 4. Hashes cracked offline over time
 5. Data sold and later leaked publicly



Timeline Overview

Year	Event
2012	Initial breach occurs
2012	LinkedIn confirms limited exposure
2016	Full dataset appears online
2016	LinkedIn forces password resets
Post-2016	Security architecture overhaul



That's all Folks!